



PROJECT ASSIGNMENT

Security Governance pack of Maxwell Software Solution

Course: Organisational Security

Ljubljana, 3/5/2026

Vishnu Viswanath Thattrakkal

Table of Contents

Contents	2
1 Abstract	3
2 Introduction.....	1
2.1 Organisation overview	1
3 Asset Register	1
4 Risk Register	2
5 Control Mapping	4
6 Policy pack.....	5
7 Access control policy.....	5
7.1 Acceptable use policy.....	5
7.2 Backup and Data Protection Policy	5
7.3 Incident response policy	6
7.4 Password policy.....	6
8 Business impact analysis (BIA)	6
9 Disaster Recovery Plan	7
9.1 Recovery objective	7
9.2 Recovery Strategy.....	8
9.3 Recovery Process.....	8
10 Conclusion	9
11 Reference	9

1 Abstract

This Security Governance Pack provides a framework aimed at improving the cybersecurity posture of Maxwell Software Solutions. The main goal of this project is to create a structured method for managing information security risks while aligning security practices with business objectives. The governance pack includes the identification and classification of organisational assets, thorough risk analysis and evaluation, and the mapping of appropriate security controls to address identified threats. It also establishes key organisational security policies to guide employee behaviour and system usage, promoting consistency and accountability throughout the organisation.

To enhance operational resilience, the framework includes a Business Impact Analysis (BIA) and a Disaster Recovery (DR) plan, allowing the organisation to maintain essential functions and recover effectively from disruptive incidents.

This approach is consistent with internationally recognised standards such as ISO 27001 and the NIST Cybersecurity Framework (Cybersecurity Framework 2013), ensuring that Maxwell Software Solutions implements best practices in risk management, control implementation, and continuous improvement. Ultimately, this governance framework seeks to strengthen the organisation's capacity to protect sensitive data, ensure regulatory compliance, and maintain business continuity in a changing threat landscape.(ISO/IEC 27001:2022 n.d.)

2 Introduction

Maxwell Software Solutions is a medium-sized software development company with approximately 100 employees. The company specialises in developing banking software, hospital applications, and inventory management systems. These systems often process highly sensitive data, including financial records, healthcare information, and proprietary business logic.

As outlined in the original network security design, Maxwell relies heavily on digital infrastructure, including cloud services, development servers, and internal networks. This dependency significantly increases the organisation's exposure to cyber threats, including ransomware, phishing attacks, and unauthorised access.

Due to the critical nature of its operations, Maxwell Software Solutions requires a structured and well-defined security governance framework. Security governance ensures that policies, procedures, and controls are aligned with business objectives while effectively managing risks.

This Security Governance Pack aims to identify and classify organisational assets, Analyse and evaluate cybersecurity risks, map appropriate security controls, define organisational security policies and ensure business continuity through BIA and DR planning

This approach aligns with industry standards such as ISO 27001 (ISO/IEC 27001:2022 n.d.) and NIST frameworks (Cybersecurity Framework 2013), ensuring that Maxwell maintains a secure and resilient operational environment.

2.1 Organisation overview

Maxwell Software Solutions is a medium-sized software development company with around 100 employees, operating in various sectors, including banking systems, hospital management applications, and inventory management solutions. The organisation manages sensitive data such as financial transactions, patient health records, and proprietary business logic, making information security a vital aspect of its operations.

The company relies heavily on digital infrastructure, which includes cloud-based services, internal development environments, and interconnected network systems. This reliance on technology improves operational efficiency but also increases the risk of cybersecurity threats, such as ransomware, phishing attacks, and unauthorised access.

As Maxwell expands its services and client base, particularly in industries with stringent regulatory requirements, the importance of strong security governance grows. A well-structured governance framework is necessary to ensure that security practices are effectively implemented, monitored, and aligned with both organisational objectives and compliance needs.

3 Asset Register

An asset register is essential for identifying all critical components within the organisation that require protection. These assets include hardware, software, data, and services.

Maxwell Software Solutions relies on multiple critical assets such as source code repositories, cloud infrastructure, and employee endpoints. These assets are categorised and evaluated based on their importance to business operations. (*How to Create an Asset Register*, 2026; *Tech Company Org Chart Templates & Most Common Tech Roles* | Workleap, n.d.)

ID	Asset	Category	criticality	Description
A1	Source Code Repository	Data	Critical	Core intellectual property of the company
A2	Development Servers	Server	Critical	Used for software development
A3	AWS EC2 Servers	Cloud	Critical	Hosts production applications
A4	Dell PowerEdge Server	Hardware	Critical	Data storage and virtualisation
A5	Firewall (NGFW)	Network	Critical	Protects against external threats
A6	Network Switch	Network	High	Provides internal connectivity
A7	Employee Laptops	Endpoint	High	Used for daily operations
A8	Azure Active Directory	Identity	Critical	Manages authentication
A9	Client Data	Data	Critical	Sensitive customer information
A10	HR System	Application	High	Stores employee records
A11	Financial System	Application	Critical	Handles financial transactions
A12	CRM System	Application	Medium	Customer relationship management
A13	QA Testing Servers	Server	High	Testing environment
A14	Backup Storage	Storage	Critical	Disaster recovery data
A15	VPN System	Network	High	Secure remote access
A16	Wi-Fi Access Points	Network	Medium	Wireless connectivity
A17	CCTV System	Physical	Medium	Physical security monitoring
A18	SIEM System	Security	Critical	Threat detection and monitoring
A19	GitHub Enterprise	Platform	Critical	Code version control
A20	Documentation Systems	Data	Medium	Internal documentation

(Table 1)

4 Risk Register

Risk management is an essential element of a perfect security governance framework, as it allows an organisation to systematically identify, assess, and mitigate potential threats to its operations and assets. For Maxwell Software Solutions, effective risk management is especially crucial due to its significant reliance on cloud-based infrastructure, which gives employees access to sensitive systems and ongoing interactions with external networks and clients. These factors greatly expand the

organisation's attack surface and increase its vulnerability to cyber threats, including ransomware, phishing, unauthorised access, and data breaches.

To ensure a structured and consistent approach, each identified risk is assessed using a standardised risk assessment methodology. This process involves analysing the likelihood of the risk occurring, which considers existing vulnerabilities and the current threat landscape, as well as the impact, which evaluates the potential severity of damage to business operations, financial stability, and organisational reputation if the risk were to materialise. These two factors are then combined to establish the overall risk level, enabling the organisation to prioritise and address risks appropriately.(Hartwell 2026)

By utilising this method, Maxwell Software Solutions can concentrate its resources on high-priority risks, implement suitable security controls, and continuously monitor and enhance its security posture. This proactive risk management approach not only diminishes the likelihood of successful cyberattacks but also ensures compliance with industry standards such as ISO 27001 and NIST frameworks.(COBIT® | Control Objectives for Information Technologies® n.d.)

ID	Risk	Chances	Impact	Risk level	Migration
R1	Ransomware attack	High	Critical	Extreme	Backup + endpoint protection
R2	Phishing attacks	High	High	High	Awareness training
R3	Credential theft	High	Critical	Extreme	MFA implementation
R4	Code repository breach	Medium	Critical	High	Access control
R5	Insider threat	Medium	High	High	RBAC + monitoring
R6	DDoS attack	Medium	High	High	Firewall + WAF
R7	Malware infection	High	High	High	Antivirus
R8	Unpatched systems	High	High	High	Patch management
R9	Weak passwords	High	High	High	Password policy
R10	Cloud misconfiguration	Medium	Critical	High	Security audits
R11	DHCP spoofing	Medium	Medium	Medium	Network controls
R12	Protocol downgrade	Low	High	Medium	Enforce TLS
R13	Data leakage	Medium	Critical	High	Encryption
R14	Backup failure	Low	Critical	High	Backup testing

R15	SIEM misconfiguration	Medium	High	Medium	Monitoring improvements
-----	-----------------------	--------	------	--------	-------------------------

(Table 2)

5 Control Mapping

Security controls are vital tools put in place to minimise or eliminate recognised risks within an organisation. For Maxwell Software Solutions, these measures aim to safeguard essential assets, including source code, client information, cloud infrastructure, and internal systems, against various cyber threats identified during the risk assessment.

Control mapping guarantees that every identified risk is managed by suitable controls. This organised strategy enhances the organisation's overall security stance and aligns with globally accepted standards like ISO 27001 and the NIST Cybersecurity Framework.(Control Mapping: What It Is & How It Can Help Simplify Your Compliance Efforts n.d.)

Control mapping is categorised into 3 parts, that is

- Prevention – prevention prevents the incidents
- Detective – identifying the incidents
- Corrective -corrective recovers from the incident

By combining these three categories, Maxwell Software Solutions adopts a defence-in-depth strategy, ensuring multiple layers of protection across its infrastructure.

Control	Type	Risk Addressed
Multi-Factor Authentication	Preventive	R3, R9
Role-Based Access Control	Preventive	R5
Network Segmentation	Preventive	R6
Next-Gen Firewall	Preventive	R6
Endpoint Protection	Preventive	R1, R7
Patch Management	Preventive	R8
Encryption (AES-256, TLS)	Preventive	R13
Backup System	Corrective	R1, R14
SIEM Monitoring	Detective	R15
Email Security	Preventive	R2
VPN Security	Preventive	R3
Security Awareness Training	Preventive	R2

(Table 3)

6 Policy pack

Policies set out the rules, guidelines, and expectations that help keep an organisation secure. Maxwell Software Solutions needs a clear and organised policy system because it deals with confidential client information, uses cloud-based technology, and faces potential cyber-attacks.

Security policies help set up clear rules for putting technical protections in place and show employees how to act properly. They make sure things are done the same way every time, people are responsible for their jobs, and they follow important rules like ISO 27001 and NIST. Even with strong technical controls in place, things can still go wrong if there are no clear policies. Human mistakes or poor management can lead to failures.

The following policies are created to deal with important risk areas found within the organisation and help maintain a safe and secure working environment.

- Access control policy
- Acceptable use policy
- Back-up policy
- Incident response policy
- Password policy

7 Access control policy

The Access Control Policy ensures that only authorised personnel can access specific systems, applications, and data based on their job functions. Maxwell Software Solutions employs Role-Based Access Control (RBAC) to allocate permissions based on responsibilities. Employees receive the minimum access necessary to complete their tasks, adhering to the principle of least privilege. Access to sensitive systems, including financial applications, development servers, and cloud environments, is limited to authorised users only.

Multi-Factor Authentication (MFA) is required for all users, particularly for remote access and administrative accounts. Access rights are regularly reviewed to eliminate outdated or unnecessary permissions. This policy helps mitigate risks such as insider threats, unauthorised access, and data breaches.

7.1 Acceptable use policy

The acceptable use policy defines how employees are allowed to use the company system, network and devices. The employees must use company resources only for the authorised business purposes and avoid downloading or installing unauthorised software. Refrain from accessing malicious software or inappropriate websites. Always follow the security procedures when handling data. The use of USB or external devices is restricted to prevent malware infection and data leakage.

7.2 Backup and Data Protection Policy

The backup and data protection ensure that critical data is protected and can be recovered in the event of system failure. The Maxwell software solution follows the 3-2-1 backup strategy

- Maintain three copies of data
- Store data on two different media types
- Keep one copy offsite or offline

Backups are conducted regularly and encompass essential systems, including databases, source code repositories, and financial records. The integrity of backups is tested periodically to confirm that data can be successfully restored. All sensitive information must be encrypted both when stored and during transmission, utilising robust encryption standards like AES-256 and TLS. This policy is vital for reducing risks associated with ransomware attacks and data loss.

7.3 Incident response policy

The Incident Response Policy outlines the steps for identifying, addressing, and recovering from cybersecurity incidents. Maxwell Software Solutions employs a systematic incident response process.

- Preparation – Establish an incident response team and tools
- Detection and Analysis – Identify and analyse suspicious activity
- Containment – Limit the spread of the attack
- Eradication – Remove the root cause of the incident
- Recovery – Restore systems and operations
- Post-Incident Review – analyse and improve response strategies

The organisation utilises monitoring tools like SIEM systems to detect threats in real-time. During an incident, affected systems may be isolated and compromised accounts deactivated. This policy ensures efficient handling of incidents, reducing damage and downtime.

7.4 Password policy

The Password Policy outlines the necessary guidelines for creating and managing secure passwords to safeguard user accounts and systems. All employees are required to use strong passwords that:

- Have at least 12 characters
- Include a mix of uppercase and lowercase letters, numbers, and special characters Are not reused across different systems
- Passwords should be updated regularly, and accounts will be locked after a specified number of unsuccessful logins attempts to protect against brute-force attacks.

Moreover, default passwords on all systems and devices must be changed immediately during setup. Users are not allowed to share their passwords with anyone. This policy is essential for reducing risks such as credential theft and unauthorised access.

8 Business impact analysis (BIA)

Business Impact Analysis (BIA) plays a vital role in security governance by assessing how disruptions can affect an organisation's operations. It identifies key business functions, establishes acceptable downtime, and prioritises recovery efforts during incidents like cyberattacks, system failures, or natural disasters.

For Maxwell Software Solutions, BIA holds particular significance because of its dependence on digital infrastructure, cloud services, and ongoing software delivery. Disruptions to critical systems can result in financial losses, harm to reputation, and erosion of customer trust. The BIA process involves identifying critical business functions and assessing.

- The impact of disruption (operational, financial, reputational) •

The maximum acceptable downtime for each function •

The priority level for recovery.

Function	Impact	Max downtime	Priority
Production systems	Service outage affecting clients and applications	4 Hr	Critical
Development	Delays in software delivery and project timelines	24Hr	High
Email systems	Communication breakdown across teams	8Hr	High
CRM System	Disruption in customer relationship management	24Hr	Medium
Finance system	Delays in billing, payroll, and transactions	48Hr	medium

(Table 4)

9 Disaster Recovery Plan

This recovery plan ensures that the organisation can recover quickly from incidents. For Maxwell Software Solutions, maintaining business continuity is essential due to its reliance on cloud infrastructure, client-facing applications, and continuous software development processes. A wellstructured DRP ensures that the organisation can minimise downtime, reduce data loss, and quickly resume normal operations after an incident((PDF) Integrating Cybersecurity and Disaster Recovery: A Unified Approach to Business Continuity n.d.)

9.1 Recovery objective

Recovery objectives define the acceptable limits for system downtime and data loss. These metrics guide the design of recovery strategies and ensure alignment with business priorities identified in the Business Impact Analysis (BIA).

Recovery Time Objective (RTO): The maximum acceptable time required to restore systems and resume operations after a disruption. For Maxwell Software Solutions, the RTO ranges from 4 to 24 hours, depending on the criticality of the system.

Recovery Point Objective (RPO): The maximum acceptable amount of data loss measured in time. The organisation defines an RPO of 1 to 4 hours, ensuring that recent data can be recovered with minimal loss. These objectives ensure that critical systems such as production servers and cloud applications are prioritised during recovery.

9.2 Recovery Strategy

Maxwell Software Solutions employs a multi-tiered recovery strategy to enhance resilience against different disruptions. This approach integrates cloud technologies, redundancy, and secure backup methods.

- **Cloud Backups (AWS):** Critical data and applications are backed up using cloud services such as AWS. This ensures availability and scalability during recovery.
- **Offline and Immutable Backups:** In addition to cloud storage, offline backups are maintained to protect against ransomware attacks. These backups cannot be modified or deleted by attackers.
- **Redundant Internet Connections:** Multiple Internet Service Providers (ISPs) are used to ensure continuous connectivity in case of network failure.
- **Virtualisation and Snapshots:** Virtual machines and system snapshots enable rapid restoration of systems, reducing recovery time significantly.
- **Network Segmentation Support:** VLAN-based segmentation (as defined in the network design) allows isolation of affected systems without disrupting the entire network.

This layered approach ensures both availability and resilience.

9.3 Recovery Process

The disaster recovery process follows a structured sequence of steps to ensure efficient and controlled restoration of operations:

- **Detection of Incident**-Security monitoring tools such as SIEM systems (e.g., Microsoft Sentinel or Splunk) detect abnormal activities and trigger alerts.
- **Isolation of Affected Systems**-Compromised systems are isolated from the network (e.g., via VLAN segmentation) to prevent the spread of the attack.
- **Threat Removal and Containment**-Malware, unauthorised access, or vulnerabilities are identified and eliminated. Compromised accounts may be disabled.
- **Restoration from Backups**-Systems and data are restored using clean, verified backups from cloud or offline storage.
- **Validation of System Integrity**-Restored systems are tested to ensure they are secure, functional, and free from malicious components.
- **Resumption of Operations**-Once validated, systems are brought back online, and normal business operations resume.
- **Post-Incident Review**-A detailed analysis is conducted to identify the root cause, evaluate the response, and implement improvements to prevent future incidents.

9.4 Importance of Disaster Recovery Planning

An effective DRP provides several key benefits:

- Minimises operational downtime
- Reduces financial losses
- Protects organisational reputation
- Ensures compliance with regulatory requirements
- Improves incident response readiness.

For Maxwell Software Solutions, the DRP works in conjunction with the Incident Response Plan and BIA to create a comprehensive resilience strategy.

10 Conclusion

Maxwell Software Solutions requires a strong security governance framework to protect its critical assets and ensure business continuity. By implementing structured risk management, security controls, and policies, the organisation can effectively defend against modern cyber threats. The integration of governance practices with technical controls such as firewalls, encryption, and monitoring systems ensures a layered security approach. This not only reduces risk but also enhances customer trust and regulatory compliance.

Overall, this governance pack provides a practical and scalable approach to achieving a secure and resilient organisational environment

11 Reference

COBIT® | Control Objectives for Information Technologies®. n.d. Retrieved May 3, 2026. <https://www.isaca.org/resources/cobit>.

Control Mapping: What It Is & How It Can Help Simplify Your Compliance Efforts. n.d. Retrieved May 3, 2026. <https://secureframe.com/blog/control-mapping>.

Cybersecurity Framework. 2013. *NIST*. <https://www.nist.gov/cyberframework>.

Hartwell, Jordan. 2026. "Cyber Security Risk Register: Definition & Examples." <https://www.cyberbunker.com/cyber-security-risk-register-definition-examples/>.

ISO/IEC 27001:2022. n.d. Retrieved May 3, 2026. <https://www.iso.org/standard/27001>.

(PDF) Integrating Cybersecurity and Disaster Recovery: A Unified Approach to Business Continuity. n.d. Retrieved May 3, 2026. https://www.researchgate.net/publication/383268245_Integrating_Cybersecurity_and_Disaster_Recovery_A_Unified_Approach_to_Business_Continuity.